

Projeto de Implementação de SIEM com Wazuh – Detecção de Brute Force e FIM

Auto: Joao Victor Campbell Fontenele

Objetivo do Projeto

O objetivo deste projeto foi implementar e validar uma solução SIEM baseada no Wazuh em ambiente controlado, com foco na detecção e correlação de eventos de segurança relacionados a ataques de força bruta e monitoramento de integridade de arquivos (FIM).

O projeto buscou simular um cenário realista de ataque contra o serviço RDP, avaliando a capacidade do SIEM em:

Centralizar e normalizar logs

Identificar padrões de comportamento malicioso

Correlacionar múltiplos eventos em curto intervalo de tempo

Elevar criticidade com base em frequência e contexto

Gerar alertas acionáveis para ambiente SOC

Além disso, foi implementada uma regra customizada para demonstrar a importância da engenharia de detecção e da adaptação de regras às necessidades específicas de cada ambiente.

Objetivos Específicos

- Implementar o Wazuh em arquitetura All-in-One em ambiente Ubuntu Server.
- Integrar agente Windows 11 para coleta de eventos de segurança.
- Configurar monitoramento de integridade de arquivos (FIM).
- Simular ataque de brute force via Hydra contra RDP.
- Desenvolver regra customizada de correlação para detecção de ataques RDP.
- Validar a eficácia da detecção através de testes práticos.

Justificativa

A crescente sofisticação de ataques de força bruta exige que organizações tenham visibilidade total sobre seus logs de autenticação. Este projeto demonstra como um SIEM pode transformar centenas de logs individuais (ID 60122 - Falha de Login) em inteligência de segurança, gerando alertas consolidados de nível crítico (Level 12) e permitindo ações defensivas como o bloqueio de contas.

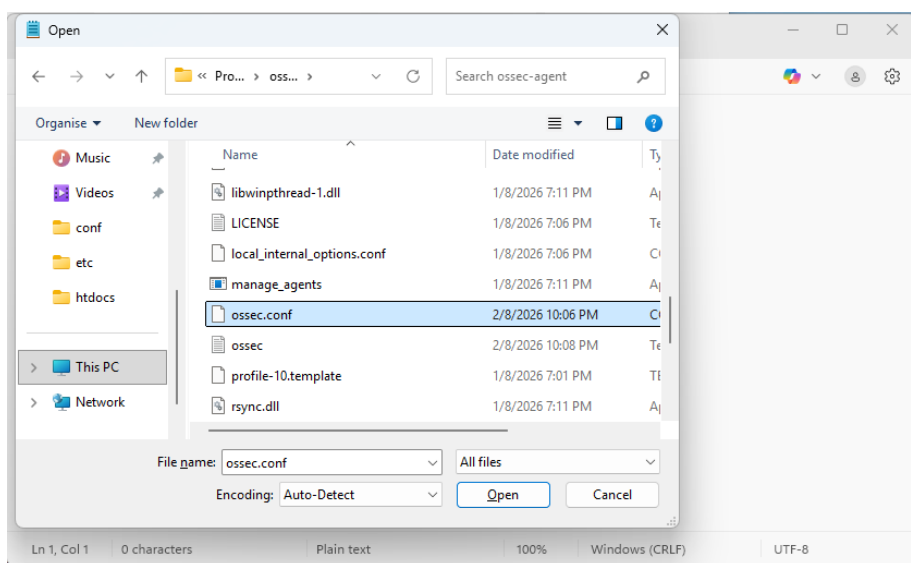
Configuração do File Integrity Monitoring (FIM)

O File Integrity Monitoring (FIM) é um componente fundamental de qualquer solução SIEM, permitindo a deteção de alterações não autorizadas em ficheiros e diretórios críticos do sistema. Esta funcionalidade é amplamente utilizada para identificar atividades suspeitas como criação, modificação ou eliminação de ficheiros potencialmente maliciosos.

Configuração do FIM no Agente Windows

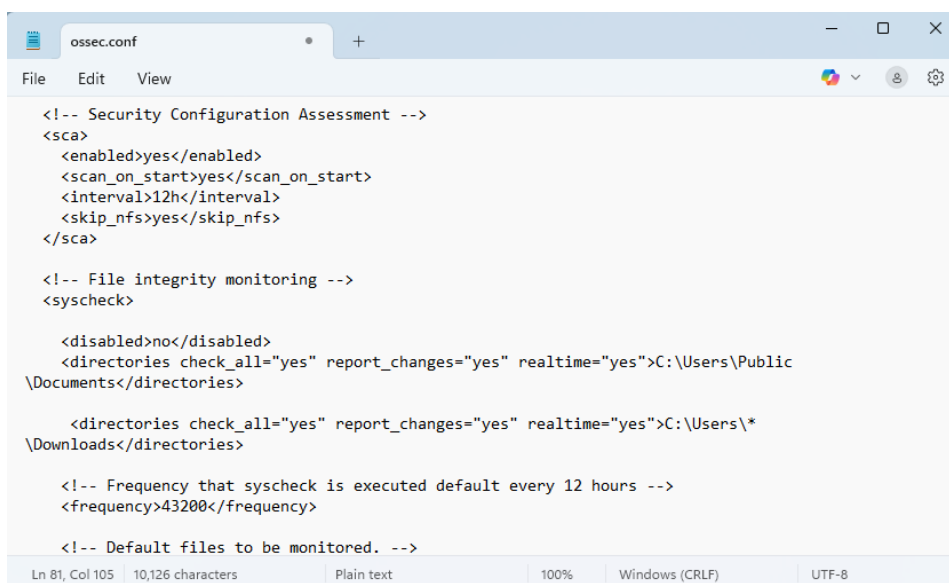
Para ativar o monitoramento em tempo real no Windows 11, foi realizada a seguinte configuração no agente Wazuh:

Aceder ao diretório de instalação do agente:



Abrir o ficheiro ossec.conf com privilégios administrativos.

Localizar a secção <syscheck> e adicionar a seguinte diretiva:



```
<directories check_all="yes" report_changes="yes" realtime="yes">
```

```
C:\Users\Public\Documents
```

```
</directories>
```

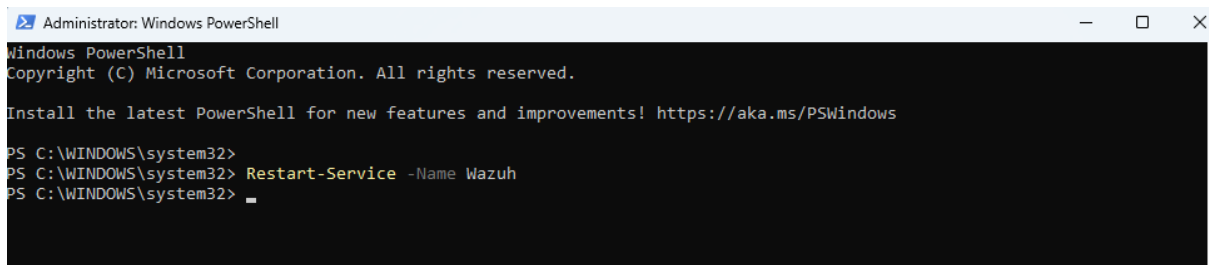
Explicação Técnica da Configuração

check_all="yes" → Monitoriza todas as alterações no diretório.

report_changes="yes" → Regista o conteúdo das alterações efetuadas.

realtime="yes" → Ativa monitoramento em tempo real, sem depender de varreduras periódicas.

Após a alteração do ficheiro de configuração, o serviço do agente foi reiniciado através do PowerShell (executado como Administrador):



```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

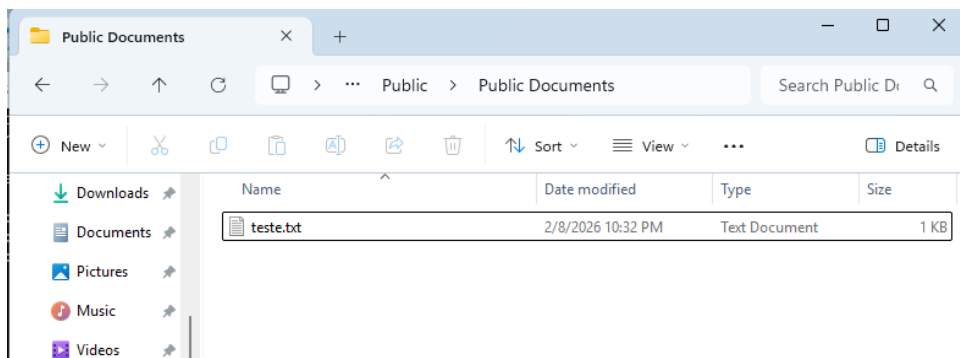
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32>
PS C:\WINDOWS\system32> Restart-Service -Name Wazuh
PS C:\WINDOWS\system32>
```

Validação da Configuração

Para validar o funcionamento do FIM:

Foi criado um ficheiro de teste (.txt) no diretório:



Após alguns segundos, o evento foi automaticamente enviado ao Wazuh Manager.

No Wazuh Dashboard, na secção Security Events, foi possível observar o alerta correspondente à criação do ficheiro.

FIM: Recent events 

Time ↓	Path	Action	Rule description	Rule Level	Rule id
Feb 6, 2025 @ 22:58:30.500	c:\users\admin\downloads\test2.txt.txt	added	File added to the system.	5	554
Feb 6, 2025 @ 22:58:30.473	c:\users\admin\downloads\new text document.txt	deleted	File deleted.	7	553
Feb 6, 2025 @ 22:58:23.323	c:\users\admin\downloads\new text document.txt	added	File added to the system.	5	554
Feb 6, 2025 @ 22:32:53.857	c:\users\public\documents\teste.txt.txt	modified	Integrity checksum changed.	7	550
Feb 6, 2025 @ 22:32:39.293	c:\users\public\documents\teste.txt.txt	added	File added to the system.	5	554

Análise do Resultado

O alerta gerado comprova que:

O agente está a monitorizar corretamente o diretório configurado.

O mecanismo de deteção em tempo real está funcional.

O SIEM consegue identificar alterações em ficheiros sem necessidade de intervenção manual.

Esta funcionalidade é particularmente relevante em ambientes corporativos, pois diretórios públicos e partilhados são frequentemente utilizados como vetor inicial para malware, ransomware ou movimentação lateral.

Detecção de Brute Force RDP com Wazuh

Objetivo do Projeto

O objetivo desta fase do projeto foi simular um ataque de força bruta contra o serviço RDP (Remote Desktop Protocol) utilizando a ferramenta Hydra, e validar a capacidade do Wazuh em:

Detectar múltiplas falhas de autenticação (Event ID 4625)

Identificar padrão de ataque por repetição de tentativas

Correlacionar eventos individuais em um alerta consolidado

Elevar o nível de criticidade com base em frequência temporal

A simulação permitiu avaliar o comportamento do SIEM perante um cenário de ataque realista e amplamente explorado em ambientes corporativos.

Arquitetura do Ambiente de Teste

O ambiente foi estruturado de forma a simular um cenário realista de ataque e detecção em infraestrutura corporativa segmentada.

Componentes do Ambiente

Ubuntu Server → Hospedando o Wazuh Manager, responsável pela correlação, análise e geração de alertas.

Windows 11 → Máquina alvo com Wazuh Agent instalado, responsável pelo envio de eventos de segurança.

Kali Linux → Máquina atacante utilizada para simular ataque de brute force.

Preparação do Ambiente

Durante a preparação do ambiente, foi identificado um desafio técnico relacionado ao sistema operacional da máquina alvo.

A máquina Windows utilizada era um dispositivo físico com Windows 11 Home, versão que não possui suporte nativo completo para funcionalidades avançadas de Remote Desktop como servidor RDP.

Para viabilizar o teste, foi necessário instalar e configurar o **RDP Wrapper**, ferramenta que permite habilitar o serviço RDP em versões do Windows que não o suportam nativamente.

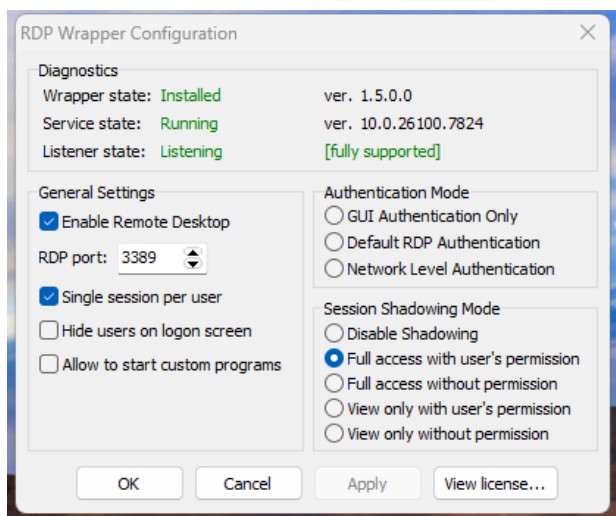
Após a configuração:

O serviço RDP foi ativado.

A porta 3389 foi validada como aberta.

A máquina tornou-se acessível para testes controlados de autenticação remota.

Esta etapa foi essencial para garantir que o cenário de ataque pudesse ser executado de forma controlada e documentada.



Criação de Utilizador para Cenário de Teste

Procedimento de Criação

A criação foi realizada via Prompt de Comando com privilégios administrativos na máquina Windows 11.

Comando executado:

```
PS C:\WINDOWS\system32> net localgroup administradores socuser /add  
Comando concluído com êxito.
```

Este comando:

Cria o utilizador socuser

Define a palavra-passe inicial

Adiciona a conta ao sistema local

Atribuição de Permissões

Para permitir autenticação via RDP, o utilizador foi adicionado ao grupo de Administradores:

```
PS C:\WINDOWS\system32> net localgroup administradores socuser /add  
Comando concluído com êxito.
```

Essa etapa garante:

Permissão para login remoto

Geração adequada de eventos de segurança no Windows

Simulação de cenário onde conta privilegiada é alvo de ataque

Verificação da Exposição do Serviço RDP (Porta 3389)

Objetivo da Verificação

Antes da execução do ataque de **brute force**, foi necessário confirmar se o serviço RDP (Remote Desktop Protocol) estava ativo e acessível na máquina alvo.

A verificação da **porta 3389** tem como finalidade:

Confirmar que o **serviço RDP** está em execução

Validar exposição do serviço na rede

Garantir que o ataque será tecnicamente viável

Simular processo real de reconhecimento realizado por um atacante

Ferramenta Utilizada

Foi utilizada a ferramenta Nmap, amplamente empregada em testes de segurança e reconhecimento de rede.

O Nmap permite:

Identificar portas abertas

Detectar serviços ativos

Mapear superfície de ataque

Avaliar possíveis vetores de exploração

Comando Executado

```
(kali㉿kali)-[~]  
$ nmap -p 3389 192.168.1.80  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-22 15:03 -0500  
Nmap scan report for joaocampbell.lan (192.168.1.80)  
Host is up (0.0022s latency).  
  
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server  
  
Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
```

Explicação técnica:

-p 3389 → Especifica a porta alvo (RDP)

192.168.1.80 → Endereço IP da máquina Windows

Resultado esperado → Estado da porta (open, closed ou filtered)

Interpretação do Resultado

Se o retorno indicar:

```
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server
```

Isso significa:

A **porta 3389** está aberta

O **serviço RDP** está ativo

O host está acessível via rede

O ataque de brute force pode ser realizado

Event Viewer → Windows Logs → Security

Segurança Número de eventos: 10 974				
Palavra...	Data e Hora	Fonte	Identifi...	Categoria da Tarefa
 Suce...	22/02/2026 20:12:17	Microsoft Windows security auditing.	4672	Special Logon
 Suce...	22/02/2026 20:12:17	Microsoft Windows security auditing.	4624	Logon

Execução do ataque de brute force com Hydra

Objetivo

Com o objetivo de validar a capacidade de detecção e correlação do SIEM, foi executada uma simulação controlada de ataque de força bruta contra o serviço RDP (**porta 3389**) da máquina Windows 11.

A ferramenta utilizada foi o Hydra, amplamente empregada em testes de segurança para automatização de tentativas de autenticação.

Antes da execução do ataque, foi realizada a verificação da exposição do serviço através do Nmap, confirmando que a porta 3389 se encontrava aberta e acessível na rede.

Objetivo da Simulação

Gerar múltiplos eventos de falha de autenticação (Event ID 4625)

Simular comportamento real de atacante externo

Avaliar a capacidade de correlação temporal do Wazuh

Validar geração de alertas críticos baseados em padrão de ataque

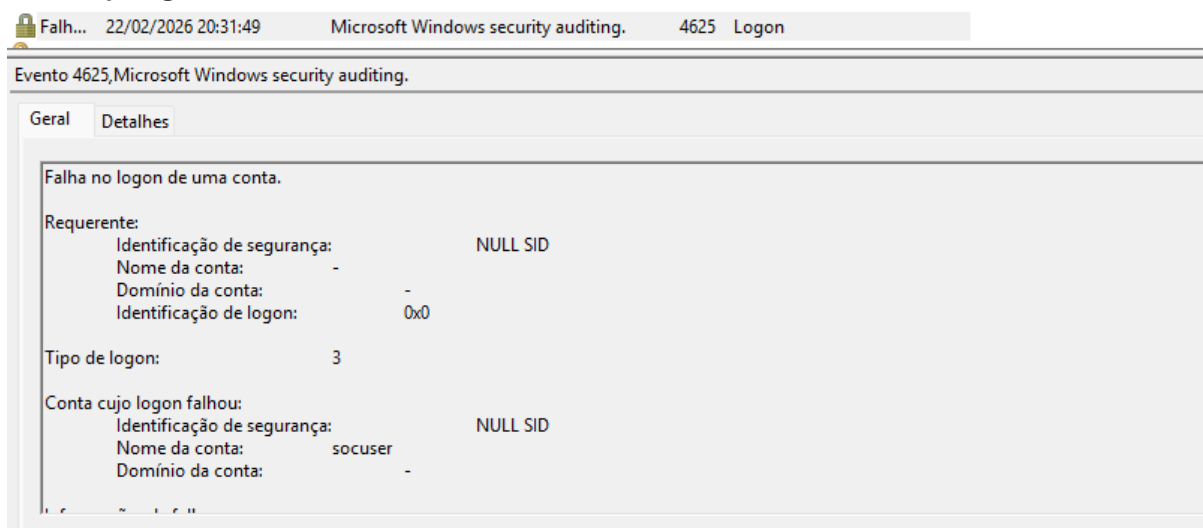
```
(kali@kali)~$ hydra -t 4 -V -l socuser -P /usr/share/wordlists/rockyou.txt rdp://192.168.1.80
hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-22 15:31:39
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking rdp://192.168.1.80:3389/
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "iloveyou" - 5 of 14344399 [child 2] (0/0)
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "princess" - 6 of 14344399 [child 3] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "123456" - 6 of 14344399 [child 0] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "12345" - 6 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "1234567" - 7 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 8 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "12345678" - 9 of 14344399 [child 2] (0/0)
[ERROR] freerdp: The connection failed to establish.
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[ERROR] freerdp: The connection failed to establish.
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "princess" - 10 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.1.80 - login "socuser" - pass "nicole" - 11 of 14344399 [child 3] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[ERROR] freerdp: The connection failed to establish.
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "12345678" - 11 of 14344399 [child 2] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[ERROR] freerdp: The connection failed to establish.
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "rockyou" - 11 of 14344399 [child 1] (0/0)
[RE-ATTEMPT] target 192.168.1.80 - login "socuser" - pass "12345678" - 11 of 14344399 [child 2] (0/0)
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-22 15:31:45
```

Parâmetros Utilizados no Hydra

- l **socuser** → Utilizador alvo fixo
- P **rockyou.txt** → Lista de palavras utilizada
- t **4** → Limitação de threads para evitar indisponibilidade do serviço
- V → Exibição detalhada das tentativas

Durante a execução do ataque, foram geradas múltiplas falhas de login no Windows Security Log, identificadas como:



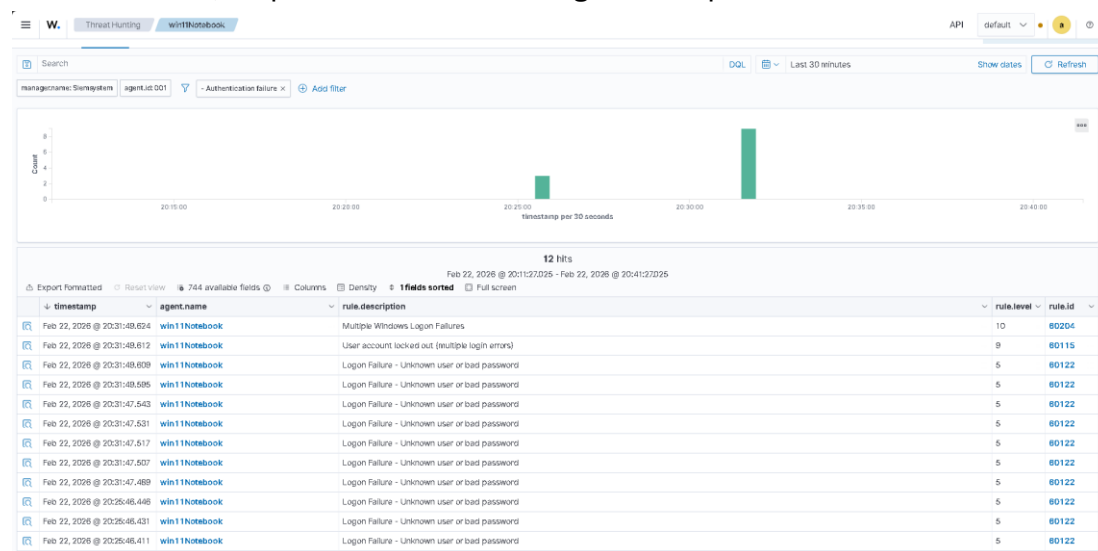
Event ID 4625 → Failed Logon

Análise e Correlação de Eventos no Wazuh Dashboard

Análise da Detecção no Wazuh Dashboard

Após a execução do ataque de força bruta, os eventos gerados no Windows foram automaticamente coletados pelo agente e enviados ao Wazuh Manager para análise.

No Dash view, foi possível observar a seguinte sequência de eventos:



Eventos Individuais

Rule ID 60115 → User Account Locked Out

Representa cada tentativa individual falhada gerada pelo ataque.

Cada entrada corresponde a uma tentativa de autenticação inválida executada pela ferramenta automatizada.

Evento de Bloqueio de Conta

Rule ID 60115 → User Account Locked Out

O sistema Windows aplicou política de segurança e bloqueou a conta após múltiplas tentativas falhadas, demonstrando eficácia da configuração de segurança local.

Correlação Automática

Rule ID 60204 → Multiple Windows Logon Failures

Este é o ponto mais relevante da análise.

Desenvolvimento de Regra de Correlação Customizada

Desenvolvimento de Regra Customizada de Correlação

Embora o Wazuh possua regras padrão para detecção de múltiplas falhas de login, foi implementada uma regra personalizada com o objetivo de aumentar a criticidade e ajustar o limiar de detecção ao cenário do laboratório.

A regra foi adicionada ao ficheiro:

```
linux@Siemssystem:~$ sudo nano /var/ossec/etc/rules/local_rules.xml
```

Objetivo da Regra

Detectar 5 falhas de login RDP

Dentro de um intervalo de 60 segundos

Elevar automaticamente o nível de severidade para 12 (Crítico)

```
<!-- Local rules -->
<!-- Modify it at your will. -->
<!-- Copyright (C) 2015, Wazuh Inc. -->

<group name="windows,authentication,rdp,bruteforce,">
  <rule id="100500" level="12" frequency="5" timeframe="60">
    <if_matched_sid>60122</if_matched_sid>
    <description>Detected possible RDP brute Force Attack (5 failures in 60s)</description>
    <mitre>
      <id>T1110</id>
    </mitre>
  </rule>
</group>
```

Lógica Aplicada

A regra foi construída com base na Rule ID 60122 (Failed Logon), utilizando correlação temporal através de:

frequency="5" → Número mínimo de ocorrências

timeframe="60" → Intervalo de tempo em segundos

if_matched_sid="60122" → Regra base monitorada

Essa abordagem permite identificar padrões característicos de ataque automatizado, diferenciando falhas ocasionais de comportamento malicioso repetitivo.

Disparo de Alerta Crítico com Regra Customizada

Disparo do Alerta Customizado

Após a implementação da regra personalizada no `local_rules.xml` e reinício do serviço do manager, o ataque de brute force foi executado novamente para validação da lógica de correlação.

Durante a simulação, foram gerados múltiplos eventos de falha de autenticação (Event ID 4625) no Windows.

Ao atingir:

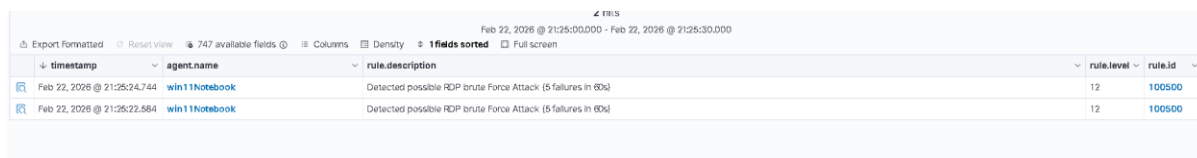
5 falhas consecutivas

Dentro de 60 segundos

O Wazuh acionou automaticamente a regra customizada:

Rule ID 100500

Level 12 (Crítico)



timestamp	agent.name	rule.description	rule.level	rule.id
Feb 22, 2026 @ 21:25:24,744	win11Notebook	Detected possible RDP brute Force Attack (5 failures in 60s)	12	100500
Feb 22, 2026 @ 21:25:22,584	win11Notebook	Detected possible RDP brute Force Attack (5 failures in 60s)	12	100500

Análise do Comportamento do SIEM

O alerta gerado demonstrou que:

A correlação temporal foi aplicada corretamente

O threshold configurado foi respeitado

O padrão de ataque foi identificado com precisão

A severidade foi elevada automaticamente

Diferentemente das regras padrão, a regra customizada permitiu maior sensibilidade ao cenário do laboratório, priorizando o incidente como crítico.

Conclusão

Este projeto demonstrou, na prática, como uma solução SIEM pode transformar eventos isolados em inteligência de segurança relevante.

Através da simulação de um ataque de força bruta contra RDP e da implementação de monitoramento de integridade de arquivos (FIM), foi possível validar:

A eficiência na coleta e centralização de logs

A capacidade de correlação automática de eventos

A identificação de padrões de ataque

A geração de alertas críticos baseados em comportamento

A criação de uma regra customizada reforçou a importância da engenharia de detecção, permitindo ajuste fino de thresholds e redução de falsos positivos.

O laboratório evidenciou como um SIEM bem configurado contribui para:

Redução do tempo de detecção (MTTD)

Priorização adequada de incidentes

Melhoria da visibilidade de ameaças

Este cenário está alinhado com a técnica T1110 (Brute Force) do framework MITRE ATT&CK, demonstrando aplicação prática de conceitos de defesa em profundidade e monitoramento contínuo.

O projeto consolidou conhecimentos fundamentais para atuação em ambientes SOC, especialmente nas áreas de análise de eventos, correlação e resposta a incidentes.